

UI / End-to-End Test Checklist

Companion to docs/qa-report-2026-09-21.md . The API has been exercised by 56 automated tests; this is the **front-end checklist** for signing the product off by hand — what to click, what to type, and what must happen. Attach this to the security audit.

Legend: [] to test · (F-x) = known gap from the QA report, expected to fail until fixed.

0. Pre-flight — build the test data first

Do this once per environment; every section below assumes it exists.

- 1. [] Register the Super Admin with the registration secret. Log in → MFA enrolment screen appears.
- 2. [] Create **Firm A** ("full permissions") with an admin — note the admin's **generated username**.
- 3. [] Create **Firm B** ("restricted") with an admin.
- 4. [] Firm A: grant FIRM_ADMIN every permission (Role Management → role → permissions).
- 5. [] Firm B: grant FIRM_ADMIN only CASE_MANAGEMENT:ACCESS/VIEW .
- 6. [] Firm A: enable modules Case Management, Project Management, Calendar, Clients, Employees, User Management, Roles, Audit, Notifications, Dashboard.
- 7. [] Firm A: inside the firm, assign ADVOCATE (case create/edit + calendar + dashboard), PARALEGAL (case view only), CLIENT (own records), and create a **custom role** (CASE_READER , case view only).
- 8. [] Firm A: create an employee **advocate**, an employee **paralegal**, a **custom-role user**, two **clients** (Client X, Client Y), one matter with Client X as a party, one project linked to Client X and one project linked to nobody.
- 9. [] Firm B: create one employee advocate (read-only) and one matter.
- 10. [] Have all four logins ready: SA, Firm A admin, Firm A advocate/paralegal, client portal.

1. Authentication

#	Test	Expected
1.1	[] Log in with a valid username + password	Lands on the role's landing page; token in the expected store
1.2	[] Log in with a wrong password	Single generic error, no hint whether the user exists
1.3	[] Log in with a non-existent user	Same message and same timing as 1.2
1.4	[] Log in with the wrong firm code	Same generic error
1.5	[] Fail 5 times, then try the correct password	Locked for 30 min with a clear message; UI offers "contact your firm admin"
1.6	[] First login after creation / after an admin reset	Forced "change password" screen; cannot navigate away; back button does not bypass
1.7	[] Change password with mismatched confirmation	Blocked inline
1.8	[] Change password to 7 characters	Blocked inline

1.9	[] Change password to aaaaaa via the admin "reset password" dialog	(F-8) currently accepted — should be rejected once the policy is unified
1.10	[] After a successful rotation, try the old/temporary password	Failed login
1.11	[] Login as a user whose admin reset their password	Expect the forced-change screen for a brand-new account; (F-8) an existing account logs straight in
1.12	[] Client login (portal) with mobile number + password	Reaches the portal only, no firm menus
1.13	[] Click "Forgot password?" if the UI shows it	(F-8) no such flow exists in the API — the link must not exist until built
1.14	[] Super Admin login	MFA challenge; QR + manual key shown; wrong 6-digit code rejected; correct one logs in
1.15	[] After SA resets MFA, log in again	Fresh QR appears and the new authenticator code works
1.16	[] Refresh the browser mid-session	Session survives; no flicker, no re-login
1.17	[] Leave the app idle past token expiry, then act	Clean re-auth prompt, no broken half-loaded screen
1.18	[] Log out, then use the browser Back button	No protected screen is served from cache
1.19	[] Log out on one device and continue on another	(F-9) no server-side logout/revocation — sessions are independent; note it in the risk log

2. Super Admin console

#	Test	Expected
2.1	[] Open the firm list	(F-4) the API has no list-firms endpoint — the screen needs it back
2.2	[] Create a firm (trial, 14 days)	Firm + admin created; success screen shows the admin's generated username and how the password is delivered
2.3	[] Open the new firm's admin list	New admin listed, status active, linked to the right firm
2.4	[] Disable then re-enable a firm admin	Status toggles and persists after refresh
2.5	[] Suspend a firm, then log in as that firm's admin in another browser	(F-1) the login still succeeds — until fixed, verify that only the badge changes; after the fix, login must be refused with a clear "firm suspended" message
2.6	[] Activate the firm again	Login works, banner disappears
2.7	[] Extend a trial by 10 days	Expiry moves forward by 10 days (not to now+10)

2.8	[] Convert a trial to permanent	Trial badge/expiry gone, status active
2.9	[] Try to extend a non-trial firm	Inline error "firm is not on trial"
2.10	[] Enable / disable a module for a firm	Toggle persists; (F-6) disabling Case Management does not block the firm's API — confirm the firm can still open cases and log this as an accepted or unacceptable risk
2.11	[] Grant a firm role a permission set	Saved; the affected users are told to re-login
2.12	[] Create a custom firm role with permissions selected in the same dialog	(F-7) the role is created empty — check the role a second time; the dialog must save permissions in the follow-up call or be fixed
2.13	[] Reset a firm admin's password from the SA console	New password works; the admin's other open session dies immediately
2.14	[] Reset a user's MFA	User must re-enrol; the old code no longer works
2.15	[] Edit global config values, delete one	Changes persist; deletion asks for confirmation; never exposes secrets in the response
2.16	[] Open global audit logs, filter by firm / user / action and paginate	Filters combine correctly; entity links open the right record
2.17	[] Log in as a firm admin and try to reach /super-admin URLs directly	403 / redirect; no SA data flashes before the redirect

3. Roles & permissions (firm side)

#	Test	Expected
3.1	[] List roles	Cloned defaults + custom roles, correct permission counts
3.2	[] Open a default role and change a permission	Saved; affected users must re-login; the change propagates after re-login
3.3	[] Try to delete ADVOCATE / PARALEGAL / CLIENT	Blocked with the "default role" message
3.4	[] Create and delete a custom role	Allowed; deletion warns if users are assigned
3.5	[] Assign a permission the firm admin does not hold	Blocked (ceiling); error explains why
3.6	[] View the users of a role	Correct list; counts match the user screen
3.7	[] Change an employee's role, then keep using that employee's open session	Session is rejected on the next call; UI shows a clean "permissions changed, please log in" and does not loop (F-10)

3.8	[] Log in as an ADVOCATE and open the roles/permissions screen by typing the URL	403 screen; no partial data
3.9	[] Give a custom role <code>EMPLOYEE:CREATE</code> and use it to add an employee	(F-13) still 403 — decide whether custom roles should work here
3.10	[] Menu visibility after each role change	Menus match the granted permissions exactly — no menu that leads to a 403 screen, and no reachable feature missing from the menu

4. Employees, clients, user management

#	Test	Expected
4.1	[] Create an employee	Success shows the generated username ; validation blocks duplicate e-mail/mobile in the same firm
4.2	[] Create an employee with the <code>FIRM_ADMIN</code> role	Blocked ("contact Super Admin")
4.3	[] Create a client with portal access ON	Client can log in to the portal
4.4	[] Toggle portal access OFF, then log in as that client	(F-2) login still succeeds today — until fixed, this is the highest-risk UI check; after the fix, login must be refused
4.5	[] Edit employee details, toggle them off	Toggle blocks their next request; their open session is refused
4.6	[] Search users by name/e-mail/username	Correct filtering, paging preserved when returning from a profile
4.7	[] Open a user profile / permissions / activity tabs	Data matches that user; permission list matches their role
4.8	[] Log in as an ADVOCATE and open another user's activity tab by URL	(F-5) it loads — a real leak; until fixed, record it as a security defect
4.9	[] Reset a user's password and MFA	Works; user must re-login
4.10	[] Bulk deactivate / bulk role change on a mixed selection	Result report lists successes and per-user failures
4.11	[] Delete a user, then search for them	Gone from lists; historical audit entries still reference them readably

5. Case Management (Firm A, then Firm B)

#	Test	Expected
5.1	[] Create a matter with parties (one "our client")	Matter number is firm-scoped; the originating court case is created automatically

5.2	[] Open the matter	Court case, parties, timeline, assignments all consistent
5.3	[] Add a second court case and switch between them	Active case pointer updates
5.4	[] Change the stage	Only <i>allowed</i> next stages are offered; an illegal stage is not selectable (and is refused server-side)
5.5	[] Record a judgment	Only possible from the judgment stage; the case becomes DECIDED; appeal deadline appears
5.6	[] Schedule a hearing (TARIK), mark it held with an outcome, add the next date	Hearing list, calendar and timeline all reflect it
5.7	[] Assign an advocate and a paralegal to the matter, then revoke one	Assignment list correct; notifications reach the assigned users
5.8	[] Calendar (day/today/upcoming) and dashboards	Counts match the matters/hearings created
5.9	[] Stale-matter list with a 90-day threshold	Only genuinely stale matters appear
5.10	[] Search matters by title/number/party	Correct results, no cross-firm rows
5.11	[] Log in as the PARALEGAL and open a matter	Read-only: create/edit/delete controls hidden or disabled and the API refuses them
5.12	[] Log in as the custom CASE_READER role	Can view; cannot create/edit — including via URL tricks
5.13	[] Log in as the employee with no case permissions	No case menu; URL entry gives a clean 403 screen
5.14	[] As Firm B, open Firm A's matter URL	404/403; nothing renders
5.15	[] Deactivate an employee mid-session and click anything	Forced out cleanly
5.16	[] Check whether a matter can be attributed to a client anywhere in the UI	(F-3) it cannot — this is the gap to close before the client portal shows cases

6. Project Management

#	Test	Expected
6.1	[] Create a project linked to Client X and one with no client	Firm list shows both; linked one shows the client name
6.2	[] Edit a project, change status (Active/On hold/Completed/Cancelled)	Persists; status filter agrees
6.3	[] Add/remove members	Owner cannot be removed; member list is correct

6.4	[] Add a credential, then list credentials	List shows metadata only — never the password
6.5	[] Reveal a credential password	Only with the reveal permission; visible for a short time; auto-hides; never written to the browser console/network log cache; revoke the clipboard note
6.6	[] As an employee without CREDENTIAL_VIEW	Credentials section hidden and API refuses; the reveal button is absent, not merely disabled
6.7	[] Create a renewal type, a yearly renewal, complete an instance	Instances generated correctly; overdue highlighting matches the due dates
6.8	[] Project dashboard	Overdue/credential/renewal counters match the detail screens
6.9	[] As Firm B, open Firm A's project URL	404/403
6.10	[] As Firm A, try to attach Firm B's client to a project	Rejected with a clear message

7. Client portal

#	Test	Expected
7.1	[] Log in as Client X	Sees only projects linked to X
7.2	[] Log in as Client Y	Sees nothing (or only its own)
7.3	[] Open another client's project by guessing its code	404/403
7.4	[] Try to reach firm screens (projects, users, roles) by URL	403 for all
7.5	[] Portal renewals view	Only renewals of own projects; correct due dates
7.6	[] Portal shows cases (once F-3 is fixed)	Only matters where <code>client_user_id</code> = the logged-in client
7.7	[] Revoke portal access while the client is logged in, then have them click something	Session refused at the next request (F-2)
7.8	[] Client attempts to download another firm's PDF/invoice URL	403

8. Notifications, audit, scraper

#	Test	Expected
8.1	[] Notification bell: unread count, mark one read, mark all read	Count updates; no stale badge after refresh

8.2	[] Open a notification	Deep-links to the right record
8.3	[] Broadcast to a role audience with users	Delivered to that role only
8.4	[] Broadcast to a role with no users	Clear failure, nothing sent
8.5	[] Broadcast as an ADVOCATE	403 / hidden control
8.6	[] Update notification preferences per channel	Persisted and respected
8.7	[] Wait for a hearing reminder / trial-expiry notice	Appears in-app (and by e-mail where configured); (missing) no realtime push — confirm the polling delay is acceptable
8.8	[] Firm audit log: filter by user, entity, action	Correct results; a deactivated user's history remains
8.9	[] Scraper: list courts, scrape a hearing, export	Export file opens and matches the list; invalid court/date input gives a clear error
8.10	[] Hearing status / matches	Matches only the firm's own cases

9. Cross-cutting behaviour

#	Test	Expected
9.1	[] Multi-tenant: run two firms in two browser profiles side by side	No data, no dropdown values, no autocomplete leakage across firms. Master data (provinces/districts/courts) may be shared — that is expected
9.2	[] Change a firm's permission set while its user is working	Next request forces re-login; UI explains why instead of dumping an error
9.3	[] Every list screen: loading, empty, no-results, error, and > 1 page	All five states designed; empty state explains how to create the first record
9.4	[] Every form: required fields, max lengths, invalid e-mail, invalid 10-digit mobile, duplicate values, whitespace-only input	Consistent inline errors; no silent failure
9.5	[] Double-submit every create/save button	Only one record created
9.6	[] Refresh on a detail page, then deep-link to it	Data reloads; a hard refresh never lands on a blank screen
9.7	[] Back button after a save	No duplicate-save form re-submission
9.8	[] Server error (turn the API off)	Friendly error + retry; no raw JSON or stack trace
9.9	[] Long text everywhere it is allowed (200+ chars in titles, 2000+ in	Truncation with tooltips; tables do not break layout

	descriptions)	
9.10	[] Unicode / Devanagari (नेपाली) in every text field	Saved and rendered correctly in lists, PDFs and exports
9.11	[] PDFs and exports (invoice, hearing export, any report)	Correct firm branding, correct data, no other firm's data, no server paths printed
9.12	[] Responsive: tablet and 13" laptop	Tables scroll or adapt; no control off-screen
9.13	[] Keyboard-only navigation and screen-reader labels on the login and main forms	Focus visible, logical order, labels announced
9.14	[] 100–200 records in lists (matters, users, audit)	Paging/filtering stays responsive; no timeouts

10. Security checks to perform *from the UI*

These are the front-end-specifically testable controls — the ones a security audit will ask about.

- [] **Token storage** — open DevTools → Application. Confirm the access/refresh tokens are not in `localStorage` readable by any XSS, or if they are, that this was a conscious decision with a short expiry. Check nothing sensitive is in `sessionStorage` /cookies without `HttpOnly`.
- [] **Logout actually clears** — after logging out, no token remains in storage, no matter survives in memory, and the Back button shows no protected content.
- [] **Broken access control (IDOR)** — take every URL containing an id (user, matter, court case, project, client, role, audit entry, invoice) and swap it for another firm's id. All must be 403/404, never a rendered record.
- [] **Hidden ≠ protected** — for every control you hide by permission, call the underlying API directly (DevTools → fetch). Hiding a button must never be the only defence.
- [] **XSS** — put `<script>alert(1)</script>` and `<img src=x onerror=alert(1)>` into every free-text field (matter title, party name, notes, client name, role name, broadcast). Must never execute; must render as text in lists, PDFs and notifications.
- [] **HTML/template injection in e-mail bodies and PDFs** — verify the same payloads in generated PDFs and e-mails do not break the template.
- [] **Sensitive data in the browser** — with a credential revealed, check the console, network tab and any logging wrapper: the plain password must not be logged or cached.
- [] **Permission list the UI trusts** — compare the `/me` permissions with what the menus show; a mismatch means one of the two is wrong.
- [] **Error messages** — force 400/401/403/404/500 and confirm none reveals SQL, class names, file paths or whether another tenant's record exists.
- [] **Rate limiting / retry storms** — hammer login and the reveal endpoint; the UI must not silently retry a login into a lockout without telling the user.
- [] **Session fixation** — log in, copy the token, log out, reuse the token via `cur1`. Until F-9 is fixed, an access token and refresh token remain valid for their full lifetime.
- [] **CSRF surface** — confirm state-changing calls need the `Authorization` header (no cookie-based auth), and that this is documented, since CSRF protection is disabled server-side.
- [] **MFA** — enrolment QR, wrong code, replay of a used code window, and reset-to-re-enrol.
- [] **Audit completeness from the UI** — every privileged action you perform in this checklist should leave an audit entry (create/edit/delete role, permission change, password/MFA reset, firm suspension, module

toggle, client portal toggle).

11. Gap regression checklist

Run these after each fix; they must flip from "current behaviour" to "expected behaviour".

Gap	UI check that should now pass
F-1	Suspended firm's user cannot log in and existing sessions stop working
F-2	Revoked client portal access blocks login and portal calls
F-3	A matter can be attributed to a client; the portal shows only that client's matters
F-4	The Super Admin firm list loads
F-5	An employee without USER_MANAGEMENT cannot open another user's activity tab
F-6	Disabling a firm's module blocks that module's screens and APIs
F-7	Creating a role with permissions selected persists them in one step
F-8	"Forgot password" self-service works; reset enforces one password policy (8+ chars); temp passwords expire/rotate
F-9	Logout (or "sign out all devices") invalidates the token server-side
F-10	A permission change produces a friendly forced re-login, not a mystery 401